

The background of the slide features a blurred image of a laptop and a tablet. The laptop screen shows a blue interface with white geometric lines and shapes, resembling a technical diagram or a network map. The tablet, held by a hand on the right, also displays a similar blue interface with white lines. The overall scene is dimly lit, with the screens providing the primary light source.

Ethical Hacking Project

Exploitation, Patching, and Technical Reporting
Penetration Testing & Ethical Hacking

Project Overview

In Scope	Out of Scope
Kioptrix 1.2 (192.168.146.129)	Other VMs on network
Tr0ll (192.168.146.130)	Denial of Service attacks
Network discovery & exploitation	Physical access attacks
Privilege escalation to root	Social engineering

Methodology



Task 1 – Planning and Target Selection

Target	Source	OS	Open Ports	Why Selected
Kioptrix 1.2	VulnHub	Fedora Core 4 (Kernel 2.6.9)	22 (SSH), 80 (HTTP)	Multiple well- documented vulnerabilities (RCE, kernel exploit)
Tr0ll	VulnHub	Ubuntu 14.04 (Kernel 3.13.0)	21 (FTP), 22 (SSH), 80 (HTTP)	Beginner-friendly: anonymous FTP, hidden directories

Ethical Commitment

Test ONLY
approved
targets

Follow HCT
ethical
guidelines

NO AI tools
(ChatGPT, etc.)

Report all
findings
honestly

Weekly Timeline



Week	Phase	Activities
Week 11	Planning	Project plan submission, VM setup
Week 12	Scanning	Network discovery, port scanning, vulnerability research
Week 13	Exploitation	Execute 3+ exploits, privilege escalation
Week 14	Reporting	Final report, fix recommendations
Week 15	Presentation	20-25 min presentation + Q&A

Task 2 – Scanning Tools and Methodology

Tools Used for Scanning

Tool	Purpose	Target
netdiscover	Network discovery	Both VMs
Nmap	Port scanning, service detection, OS fingerprinting	Both VMs
Nikto	Web vulnerability scanning	Both VMs
gobuster	Directory brute forcing	Both VMs
searchsploit	Exploit research	Both VMs

Scanning Commands Used

Network
Discovery

netdiscover -r 192.168.146.0/24

Full Port Scan
(Kioptrix)

nmap -p- -sV -sC -O -A 192.168.146.129

Full Port Scan
(TrOll)

nmap -p- -sV -sC -O -A 192.168.146.130

Web
Vulnerability Scan

nikto -h <http://192.168.146.129>

nikto -h <http://192.168.146.130>

Directory Brute
Forcing

gobuster dir -u http://192.168.146.129 -w
/usr/share/wordlists/dirb/common.txt

Task 2 – Key Scanning Findings (Kioptrix 1.2)

Kioptrix 1.2 - Nmap Results

- **OS Detection:** Linux 2.6.9 – 2.6.33

Port	State	Service	Version
22/tcp	open	SSH	OpenSSH 4.7p1
80/tcp	open	HTTP	Apache 2.2.8, PHP 5.2.4

Critical Findings from Nikto

Finding	Severity
Apache/2.2.8 is outdated (EOL)	High
PHP/5.2.4 is outdated (EOL)	High
phpMyAdmin directory exposed	Critical
HTTP TRACE method enabled	Medium

Discovered Directories (gobuster)

Directory	Importance
/gallery/	Gallery CMS (potential RFI)
/phpmyadmin/	CRITICAL – Database interface
/modules/	Listable directory

Task 2 – Key Scanning Findings (Tr0ll)

Tr0ll – Nmap Results

- **OS Detection:** Linux 3.2 – 4.14

Port	State	Service	Version
21/tcp	open	FTP	vsftpd 3.0.2
22/tcp	open	SSH	OpenSSH 6.6.1p1
80/tcp	open	HTTP	Apache 2.4.7

Critical Finding: Anonymous FTP is ALLOWED!

```
| ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_-rwxrwxrwx 11000 0      8068 Aug 10 2014 lol.pcap [NSE: writeable]
```

Discovered Directories

Directory	How Discovered
/secret/	robots.txt
/sup3rs3cr3tdirlol/	lol.pcap analysis
/0x0856BF/	roflmao binary output

Task 2 – Vulnerability Mapping (CVEs)

- **Kioptrix 1.2**

Vulnerability	CVE	Exploit	Risk
Apache mod_ssl OpenFuck	CVE-2002-0082	764.c, 47080.c	Critical
Apache CGI RCE	CVE-2012-1823	29290.c, 29316.py	Critical
DirtyCow	CVE-2016-5195	40839.c, 40616.c	High
phpMyAdmin Exposure	N/A	Manual	Critical

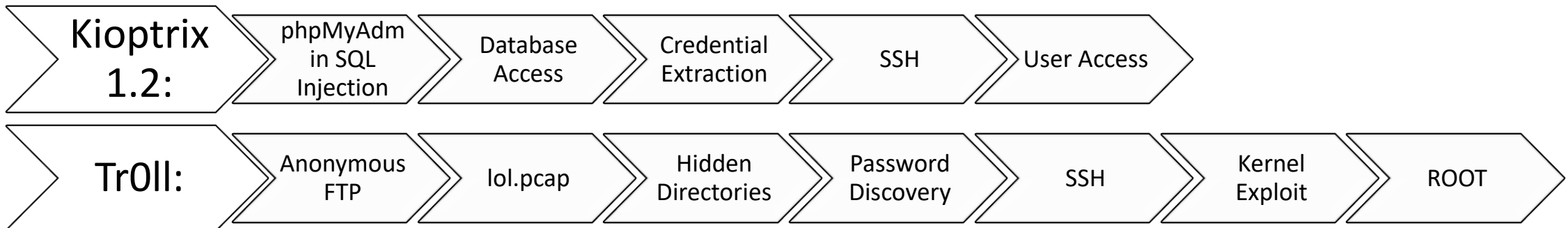
- **TrOll**

Vulnerability	CVE	Exploit	Risk
Anonymous FTP	N/A	Manual	Medium
Overlayfs Priv Esc	CVE-2015-1328	37292.c	High

Task 3 – Exploitation Overview

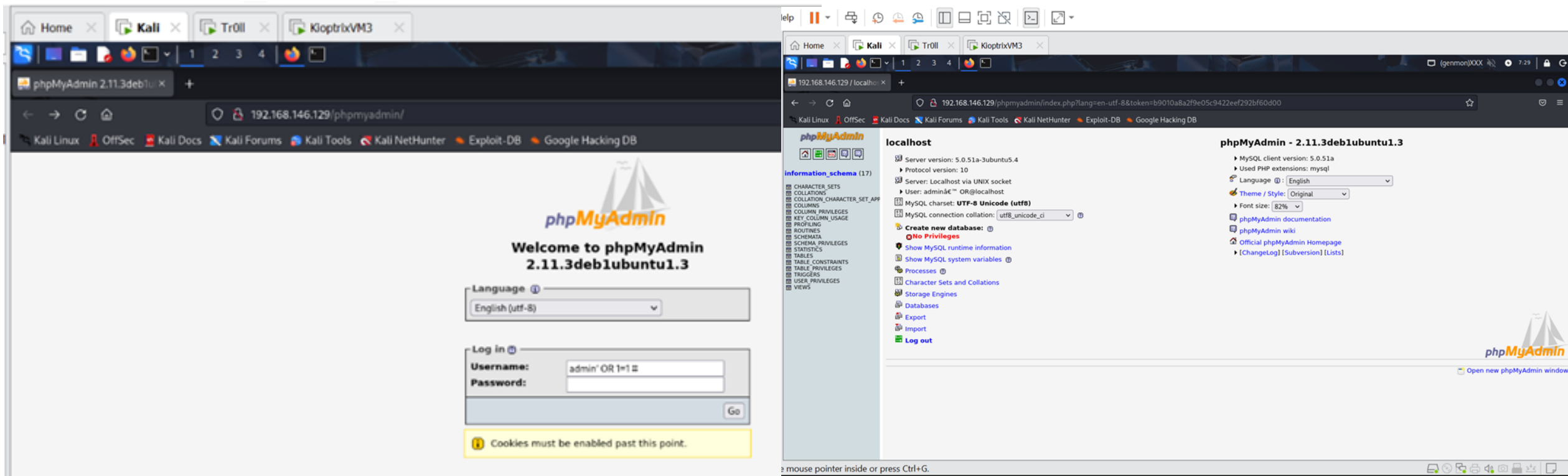
- Successful Exploits (4 Total – Exceeded Requirement)

Exploit	Target	Vulnerability	Access Gained
#1	Kioptrix 1.2	phpMyAdmin SQL Injection	phpMyAdmin Access
#2	Kioptrix 1.2	Weak Password Storage (MD5)	SSH Access (loneferret)
#3	TrOll	Anonymous FTP + Hidden Directories	SSH Access (overflow)
#4	TrOll	Kernel Exploit (CVE-2015-1328)	Root Access



Exploit 1 – phpMyAdmin SQL Injection (Kioptrix 1.2)

- **Vulnerability:** Authentication Bypass via SQL Injection
- **Where:** <http://192.168.146.129/phpmyadmin/>



Exploit 2 – Credential Extraction & SSH (Kioptrix 1.2)

- **Vulnerability:** Weak Password Storage (MD5 without salt)
- **Result:** SSH access as user loneferret

SQL query:

```
SELECT *  
FROM dev_accounts  
LIMIT 0, 30
```

Show: 30 row(s) starting from record # 0
in horizontal mode and repeat headers after 100 cells
Sort by key: None

		id	username	password
☐		1	dreg	0d3eccfb887aabd50f243b3f155c0f85
☐		2	loneferret	5badcaf789d3d1d09794d8f021f40f0e

Check All / Uncheck All With selected:

Show: 30 row(s) starting from record # 0
in horizontal mode and repeat headers after 100 cells

		username	password
☐		admin	n0t7t1k4

Check All / Uncheck All With selected:

Show: 30 row(s) starting from record # 0

The screenshot shows the CrackStation website, a free password hash cracker. The interface includes a text input field for pasting hashes, a "Crack Hashes" button, and a results table. The results table shows two hashes: "0d3eccfb887aabd50f243b3f155c0f85" and "5badcaf789d3d1d09794d8f021f40f0e", both identified as MD5 hashes. The first hash is cracked to "Mast3r" and the second to "starwars". The website also features a "Download CrackStation's Wordlist" link and a "How CrackStation Works" section.

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

```
0d3eccfb887aabd50f243b3f155c0f85  
5badcaf789d3d1d09794d8f021f40f0e
```

I'm not a robot
This site is exceeding 30CAPTCHA
Entercode from audio

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-ha1, sha1, sha224, sha256, sha384, sha512, rpeMD160, whirlpool, MySQL 4.1+ (sha1[sha1_bin]), QubersV3.1BackupDefaults

Hash	Type	Result
0d3eccfb887aabd50f243b3f155c0f85	md5	Mast3r
5badcaf789d3d1d09794d8f021f40f0e	md5	starwars

Color Codes: ■ Exact match, ■ Partial match, ■ Not found.

[Download CrackStation's Wordlist](#)

How CrackStation Works

CrackStation uses massive pre-computed lookup tables to crack password hashes. These tables store a mapping between the hash of a password, and the correct

Exploit 3 – Tr0ll Information Disclosure & SSH

- **Vulnerability:** Anonymous FTP + Hidden Directories
- **Result:** SSH access as user overflow

The image is a collage of four screenshots illustrating a security exploit on a Tr0ll system.

Top Left Screenshot: A terminal window showing an FTP session. The user connects to 192.168.146.130, logs in anonymously, and lists the contents of the local directory. The output shows a file named `lol.pcap` with a size of 8068 bytes.

Top Right Screenshot: A browser window showing the directory listing of `/sup3rs3cr3tdir10/`. The listing shows a file named `roflmao` with a size of 7.1K, last modified on 2014-08-11 18:45.

Bottom Left Screenshot: A browser window showing the directory listing of `/0x0856BF/`. The listing shows a file named `good_luck/` with a size of 23:59, last modified on 2014-08-12 23:59.

Bottom Right Screenshot: A browser window showing the directory listing of `/0x0856BF/good_luck/`. The listing shows a file named `which_one_lo1.txt` with a size of 23:58, last modified on 2014-08-12 23:58.

Exploit 4 – Privilege Escalation to Root (Tr0ll)

- **Vulnerability:** Overlayfs Kernel Exploit (CVE-2015-1328)
- **Result:** FULL ROOT ACCESS on Tr0ll

```
Ubuntu 14.04.1 LTS troll tty1
troll login: Pass.txt
Password:
Login incorrect
troll login: overflow
Password:
Last login: Fri Apr 10 13:30:56 PDT 2026 on tty1
Welcome to Ubuntu 14.04.1 LTS (GNU/Linux 3.13.0-32-generic i686)

 * Documentation:  https://help.ubuntu.com/

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

No directory, logging in with HOME=/
$ uname -a
Linux troll 3.13.0-32-generic #57-Ubuntu SMP Tue Jul 15 03:51:12 UTC 2014 i686 i686 i686 GNU/Linux
$
```

```
Kali - VMware Workstation
File Edit View VM Tabs Help
[Icons] [Terminal Icon]

Home x Kali x Tr0ll x
[Icons] 1 2 3 4 [Terminal Icon]
(genmon)XXX 17:22

Applications
File Actions Edit View Help

(root@kali) - [/home/kali]
#python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
|
```

Exploitation – What Worked & What Didn't

- What Worked

Exploit	Success Factor
phpMyAdmin SQL Injection	Weak input validation
Password hash cracking	MD5 without salt → easily cracked
Anonymous FTP on Tr0ll	Misconfiguration → complete directory enumeration
Kernel exploit (CVE-2015-1328)	Unpatched kernel → root escalation

- What Didn't Work

Attempt	Reason
OpenFuck (mod_ssl) exploit	OpenSSL version incompatibility
SQL INTO OUTFILE file write	Limited MySQL privileges (GRANT USAGE only)

Task 4 – Fix Recommendations (Kioptrix 1.2)

Fix 1: phpMyAdmin SQL Injection

Vulnerability: SQL Injection Authentication Bypass

Fix: Enable proper authentication, restrict IP access

Command: `$cfg['Servers'][$i]['auth_type'] = 'cookie';`

Verify: SQL injection attempt → "Access denied"

Fix 2: Weak Password Storage (MD5)

Vulnerability: MD5 hashing without salt

Fix: Use strong hashing (bcrypt/Argon2), enforce password policy

Command: `ALTER USER 'user'@'localhost' IDENTIFIED WITH caching_sha2_password BY 'NewStrongP@ss!';`

Verify: Check plugin: `SELECT plugin FROM mysql.user;`

Fix 3: Exposed phpMyAdmin

Vulnerability: phpMyAdmin accessible without authentication

Fix: Remove or add .htaccess authentication

Command: `rm -rf /var/www/html/phpmyadmin` OR add AuthType Basic

Verify: Access URL → 403 Forbidden or login prompt

Task 4 – Fix Recommendations (Tr0ll)

Fix 4: Anonymous FTP Access

Vulnerability: Anonymous FTP allowed

Fix: Disable anonymous login

Command: Edit /etc/vsftpd.conf: anonymous_enable=NO → systemctl restart vsftpd

Verify: ftp with anonymous → "530 Permission denied"

Fix 5: Hidden Directory Disclosure

Vulnerability: Sensitive directories exposed

Fix: Remove directories, update robots.txt, disable directory listing

Command: rm -rf /var/www/html/secret + Options -Indexes in Apache config

Verify: Access URLs → 404 Not Found

Fix 6: Kernel Exploit (CVE-2015-1328)

Vulnerability: Unpatched kernel 3.13.0

Fix: Update kernel to patched version

Command: apt-get update && apt-get install linux-image-generic && reboot

Verify: uname -r shows ≥ 3.13.0-32-generic

General Security Recommendations

Best Practices for Both Systems

Recommendation	Implementation
Use strong passwords	Minimum 12 characters, mix of letters, numbers, symbols
Keep software updated	Regular apt-get update && apt-get upgrade
Disable unused services	systemctl disable <service>
Remove unnecessary files	Delete backup files, test files, exposed binaries
Implement security headers	X-Frame-Options: DENY, X-Content-Type-Options: nosniff
Regular security audits	Weekly vulnerability scans (OpenVAS, Nessus)

Before vs After Security Posture

Area	Before	After
phpMyAdmin	No authentication	Authentication required
FTP	Anonymous access allowed	Authenticated only
Passwords	MD5 (crackable)	bcrypt/Argon2
Kernel	3.13.0 (vulnerable)	Patched version
Hidden directories	Exposed	Removed/restricted

Conclusion & Key Takeaways

- 1. SQL Injection remains critical** – One injection led to complete database compromise
- 2. Weak password storage is dangerous** – MD5 without salt cracked in seconds
- 3. Information disclosure leads to compromise** – Hidden directories on Tr0ll exposed passwords
- 4. Kernel vulnerabilities are game-changers** – CVE-2015-1328 allowed user → root escalation
- 5. Defense in depth is essential** – Multiple layers of security would have prevented these attacks